



By
Quit

Contract Review
Issue date
7/14/2026

Overview

Luci Market is an ETH-denominated ERC-721 marketplace with non-escrowed fixed-price listings, escrowed token/collection/trait bids, allowlist-gated fulfillment, optional sanctions checks, and royalties calculated by an owner-configured external royalty model. The main trust assumptions are the marketplace owner, the royalty model owner, the configured sanctions list, the configured royalty model, and allowed ERC-721 collections.

Contracts in scope for this review include:

- `src/LuciMarket.sol`
- `src/LuciRoyaltyModel.sol`
- `src/interfaces/ISanctionsList.sol`

This review is based on commit `ff1b13370bbae56915b1700d08f85d83eab056cc` and remediations as of `28960f24f58f4c7a96dac6716598ddb29dbf57ba`, and aims to identify security vulnerabilities, opportunities for gas optimization, and general best-practice recommendations with regard to the contracts in scope. The review should not be considered an endorsement of the project, nor is it a guarantee of security.

Findings

L-01: Royalty changes can alter expected seller proceeds for existing listings

Severity: Low

Status: *Resolved in `src/LuciMarket.sol:239-247,315-318`. Listings now snapshot `royaltyAmount` when they are created or refreshed, and settlement pays that stored amount*

Listings recorded only the gross sale price, while settlement calculated royalties from the royalty model's current state. The royalty recipient, collection mint price, token override, or marketplace royalty model could therefore change after a seller listed and before a buyer settled, including through a privileged transaction ordered ahead of the sale. This could reduce the seller's expected net proceeds even though the listing price itself did not change.

I-01: Unused declarations/misleading comments

Severity: Informational

Status: *Resolved in `src/LuciMarket.sol` and `src/LuciRoyaltyModel.sol`. The unused declarations were removed, and `_safeTransferEth` now correctly documents its gas cap.*

`CollectionMinHoldTimeSet` and `MinHoldTimeTooLong` were declared but unused, `LuciRoyaltyModel.CollectionOrTokenNotAllowed` was unused, and `_safeTransferEth` said it forwarded all gas although the implementation capped the call at `100_000` gas.

I-02: Sanctioned sellers cannot cancel their own listings

Severity: Informational

Status: *Resolved in `src/LuciMarket.sol:283-295`. `delist` no longer performs a sanctions check.*

`delist` checked `msg.sender` against the sanctions list, so a seller who became sanctioned could not remove their own listing. This did not create a direct fulfillment risk because `buy` also checked `listing.seller` and reverted while the seller remained sanctioned.

G-01: Avoid loading collection royalty config when a token override exists

Severity: Gas Optimization

Status: *Resolved in `src/LuciRoyaltyModel.sol:79-86`. The royalty model loads the token override first and reads the collection configuration only when no override is enabled.*

`calculateRoyalty` loaded both `collections[collection]` and `tokenOverrides[collection][tokenId]` before deciding which mint price applied. Since token overrides take precedence, the collection configuration read was unnecessary whenever `tokenOverride.enabled` was true.

G-02: Approval check during listing can be skipped

Severity: Gas Optimization

Status: *Acknowledged: `list` intentionally retains the marketplace-approval check so incorrectly configured listings fail loudly before they are published.*

`list` checks both current token ownership and marketplace approval before storing a listing. The ownership check prevents arbitrary callers from overwriting a token owner's listing, but the approval check proves only moment-in-time transfer eligibility and can be revoked immediately after listing. Fulfillment independently transfers the NFT and therefore already rejects a stale or unapproved listing.

G-03: Buyer-side ownership precheck is redundant with settlement transfer

Severity: Gas Optimization

Status: *Resolved in `src/LuciMarket.sol:297-318`. The redundant `ownerOf` precheck was removed, and the settlement transfer now establishes current ownership and approval.*

`buy` called `ownerOf` to confirm the stored seller still owned the token before settlement. The later ERC-721 transfer from that same seller already reverted if ownership or approval was no longer valid, making the successful-path ownership precheck redundant.

G-04: Use transferFrom instead of safeTransferFrom for marketplace settlement

Severity: Gas Optimization

Status: Resolved in *src/LuciMarket.sol:764-789*. Settlement now uses *transferFrom*, avoiding receiver callbacks.

_settleSale used *safeTransferFrom*, which added ERC-721 receiver callback handling when the buyer was a contract. Buyers and bidders explicitly opted into receiving the NFT by calling *buy* or placing a bid, so using *transferFrom* could remove this callback cost and avoid invoking arbitrary recipient code during settlement.

G-05: Token bid acceptance ownership and approval prechecks are redundant

Severity: Gas Optimization

Status: Resolved in *src/LuciMarket.sol:411-468*. Bid acceptance no longer performs separate ownership or approval prechecks; the ERC-721 *transferFrom* call enforces both conditions and failures restore the bid and listing state.

Token-bid acceptance checked that *msg.sender* owned the token and had approved the market before calling settlement. The settlement transfer from *msg.sender* to the bidder already enforced both conditions, so these successful-path prechecks provided clearer errors but added avoidable external calls.

G-06: Bid lifecycle logic can be consolidated around BidType

Severity: Gas Optimization

Status: Resolved in *src/LuciMarket.sol:325-468*. Placement, increase, and acceptance now use the common *BidSelector/BidType* interface and generic lifecycle events. The developer intentionally did not add batch placement, increase, or acceptance because those are not expected user actions.

BidType was used by batch extension and cancellation, while placement, increase, and acceptance duplicated much of the same lifecycle logic across token, collection, and trait bids. Consolidating these paths around a typed selector could reduce deployed bytecode and reduce the risk that future validation changes diverge across the three bid types.

G-07: Pack token trait storage with Uint32Map

Severity: Gas Optimization

Status: Resolved in *src/LuciMarket.sol:7,17,89,604-626*. Trait storage now uses *Solady LibMap.Uint32Map*; the external *tokenTraits* getter preserves the prior interface.

tokenTraits stored one *uint32* trait word per token in a nested mapping, giving each token its own storage slot. *Solady LibMap.Uint32Map* packs eight *uint32* values per slot, substantially reducing the storage footprint of dense sequential token IDs while preserving

one-word reads for trait-bid acceptance.

G-08: Use LibBitmap for sequential allowed token ranges

Severity: Gas Optimization

Status: Acknowledged

`allowedTokens` stored each individually allowed shared-contract token in a separate mapping slot. For a shared contract with dense sequential token IDs, Solady `LibBitmap` could represent 256 token IDs per storage slot and range helpers could reduce the number of storage writes required for batch allowlisting.